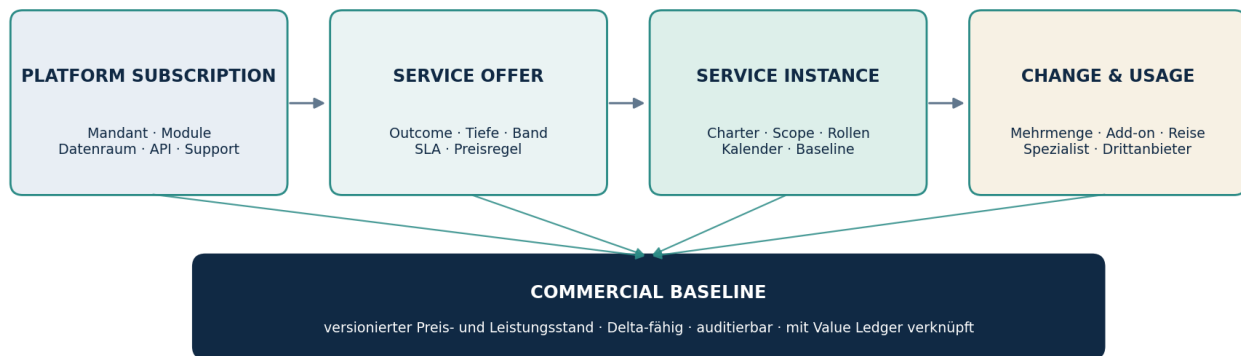


Servicekatalog, Pakete, SLAs & Preislogik

Eine modulare, transparente und wirtschaftlich steuerbare Angebotsarchitektur für Plattform, Transition und wiederkehrende Managed Services.

Kommerzielle Architektur: vom Produktzugang zur kontrollierten Kundenleistung



ARBEITSBEZEICHNUNG ISMS Managed Service Platform
VERSION 1.0 | **STATUS** Erstellt | **STAND** 21.07.2026
ABHÄNGIGKEITEN Dokument 00 bis 13

Dokumentauftrag & Verbindlichkeit

Dokument 14 ist die kanonische Quelle für Servicefamilien, kaufbare Offers, Service-Tiefen, Paketarchitektur, Leistungsversprechen, Price Book, Commercial Baseline, Preisbänder, Mengentreiber, Rabatte, Mehrmengen, Reise- und Drittanbieterlogik. Nachfolgende Dokumente dürfen technische und operative Details konkretisieren, aber diese kommerzielle Semantik nicht still verändern.

Steuerungsfeld	Festlegung
Dokument-ID	14
Status	Erstellt - Version 1.0
Owner	Product Architecture / Service Portfolio & Commercial Model Owner
Gültigkeit	Bis zur freigegebenen Nachfolgeversion
Preisstatus	Alle Preisbänder sind synthetische Designannahmen und keine realen Angebote.
Änderungskontrolle	Änderungen an Service Offers, Preisformeln, SLA-Bändern, Paketgrenzen oder Commercial Baseline benötigen Version, Impactanalyse, Tests und Freigabe.
Zentrale Nachfolger	Dokument 15 bis 20C

Inhalt

1 Auftrag · 2 Summary · 3 Verfassung · 4 Preisobjekte · 5 Katalog · 6 Tiefen · 7 Pakete · 8 SLA · 9 Preisformel · 10 Treiber · 11 Lizenz · 12/13 Preisbänder · 14 Add-ons · 15 Marktanker · 16 Business Case · 17 Unit Economics · 18 Rabatte · 19 Usage/Change · 20 Reise · 21 Angebots-UX · 22 Lifecycle · 23 Governance · 24 bis 33 Szenarien und Governance

1. Dokumentauftrag und Abgrenzung

Dieses Dokument konkretisiert die kommerzielle Ausprägung des in Dokument 13 definierten Managed-Service-Betriebsmodells. Es ist die kanonische Quelle für:

- Servicekatalog, Servicefamilien und Service Offers,
- Service-Tiefen und Paketlogik,
- Standard-Scope, optionale Add-ons und Ausschlüsse,
- SLA-, OLA- und Service-Level-Architektur,
- Preisobjekte, Preistreiber, Mengeneinheiten und Kalkulationslogik,
- Plattformlizenz, einmalige Transition und laufende Managed Services,
- marktnahe, aber ausdrücklich illustrative Preisbänder,
- Rabatte, Laufzeiten, Indexierung, Mehrmengen und Change Requests,
- Reisekosten, Vor-Ort-Leistungen und Drittanbieter-Kosten,
- Kundennutzen, Provider-Unit-Economics und Margin Guardrails,
- transparente Angebots- und Konfigurator-Erlebnisse,
- Demo-Szenarien und Akzeptanzkriterien.

Nicht Gegenstand dieses Dokuments sind konkrete interne Preise, vertrauliche Kalkulationssätze, individuelle Angebote einer bestimmten Beratungsgesellschaft oder Zertifizierungsgebühren eines Auditunternehmens. Alle Preisbeispiele sind synthetische Produktannahmen oder öffentlich beobachtbare Marktanker und müssen vor realer Vermarktung validiert werden.

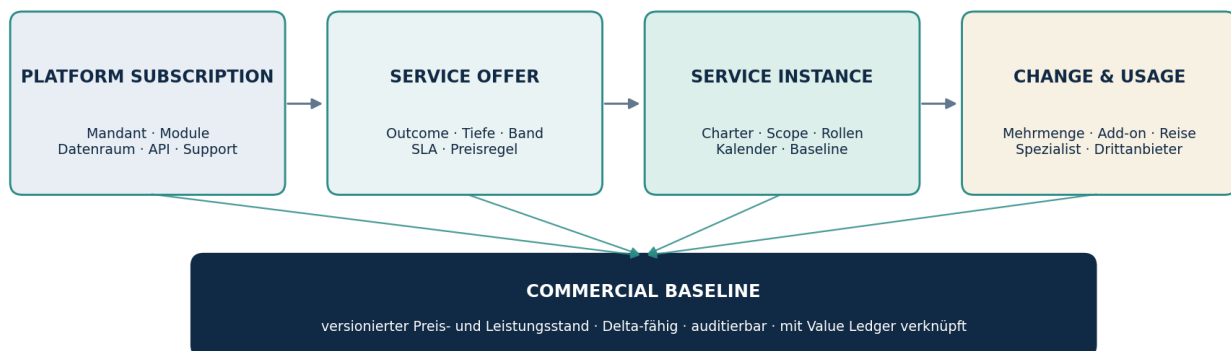
Detaillierte Ressourcen-, Skill-, Kalender-, Reise- und Portfoliooptimierung folgt in Dokument 15. Kunden-Onboarding und Zielprofil folgen in Dokument 16. Integrations-, Technik-, Sicherheits-, KI- und Claude-Code-Details folgen in Dokument 17 bis 20C.

2. Executive Summary

Die kommerzielle Architektur besitzt vier getrennte Ebenen:

- 1. Platform Subscription:** Zugang zur mandantenfähigen Plattform, zum digitalen Zwilling, zu ISMS-Kernfunktionen, Decision Center, Collaboration und Reporting.
- 2. Service Offer:** standardisierte, kaufbare Ausprägung eines Managed Service mit Outcome, Scope, Leistungsband, Service-Level und Preislogik.
- 3. Service Instance:** kundenspezifisch konfigurierte und freigegebene Leistung mit Charter, Rollen, Kalender, Mengengerüst und kommerziellem Baselinewert.
- 4. Change und Usage:** genehmigte Mehrmengen, Zusatzleistungen, Vor-Ort-Tage, Spezialisten, Drittanbieter und Scope-Änderungen.

Kommerzielle Architektur: vom Produktzugang zur kontrollierten Kundenleistung



Der Katalog ist modular, aber nicht beliebig. Kunden sollen Services hinzufügen, reduzieren oder intern übernehmen können, ohne dass das Betriebsmodell zerfällt. Gleichzeitig muss der Provider vor unkontrolliertem Scope, nicht kalkulierbaren Serviceversprechen und unsichtbarer Zusatzarbeit geschützt werden.

Die Preislogik wird deshalb nicht ausschließlich an Mitarbeitendenzahl, User Seats oder Beraterstunden gekoppelt. Sie berücksichtigt vor allem:

- Scope und Anzahl rechtlicher Einheiten,
- Zielprofil und regulatorische Komplexität,

- Objekt- und Kontrollmenge,
- Datenqualität und Integrationsgrad,
- Service-Tiefe und Verantwortung,
- Frequenz, Reaktionszeit und Verfügbarkeit,
- Skill Mix, Review- und Freigabetiefe,
- Vor-Ort-Anteil, Reise und Sprach-/Regionsbedarf,
- erwartete Schwankung und Risikoreserve.

Die Plattform zeigt dem Kunden nicht nur den Preis, sondern auch **welches Ergebnis, welches Leistungsband, welche Annahmen und welche Grenzen** damit verbunden sind. Das verhindert, dass ein günstiges Paket später durch versteckte Zusatzkosten oder permanente Change Requests entwertet wird.

3. Kommerzielle Verfassung

3.1 Globale Prinzipien

- **CP01 - Outcome vor Stunden:** Das primäre Kaufobjekt ist ein Ergebnis- und Leistungsversprechen, nicht ein anonymes Stundenkontingent.
- **CP02 - Plattform und Service sind getrennt:** Softwarelizenz, Transition, Managed Service, Projekt und Drittanbieter-Kosten werden separat ausgewiesen.
- **CP03 - Modular, aber kohärent:** Services können einzeln gebucht werden, besitzen jedoch definierte Voraussetzungen, Abhängigkeiten und gemeinsame Governance.
- **CP04 - Transparenter Mengentreiber:** Jede wiederkehrende Gebühr besitzt mindestens eine verständliche Mengeneinheit oder ein klar beschriebenes Leistungsband.
- **CP05 - Kein unlimitiertes Versprechen ohne Guardrail:** „Unlimited“ ist nur zulässig, wenn Fair-Use-Grenzen, Priorisierungsregeln und Kapazitätsannahmen explizit sind.
- **CP06 - SLA misst das Beherrschbare:** Reaktions-, Bearbeitungs- und Lieferziele werden getrennt. Ein Provider garantiert keine Ergebnisse, die von Kundenmitwirkung oder externen Dritten abhängen.
- **CP07 - Keine Zertifizierungsgarantie:** Audit- oder Zertifizierungserfolg kann vorbereitet und unterstützt, aber nicht garantiert werden.
- **CP08 - Preisänderungen sind versioniert:** Neue Preise gelten nur für neue Offers, Verlängerungen oder freigegebene Änderungen; keine stille rückwirkende Anpassung.
- **CP09 - Wert und Preis bleiben unterscheidbar:** Hoher Kundennutzen rechtfertigt nicht automatisch beliebige Preise; Preis muss markt-, kosten- und leistungsseitig begründbar bleiben.
- **CP10 - Rabatte verändern keinen Scope:** Ein Rabatt reduziert Preis, nicht still die vereinbarte Qualität oder Verantwortung.
- **CP11 - Interne Alternative bleibt sichtbar:** Serviceempfehlungen zeigen auch Selbstbetrieb und Nichtstun-Option, damit die Plattform nicht zur versteckten Verkaufsmaschine wird.
- **CP12 - Exit bleibt möglich:** Datenportabilität, Handover und Serviceabbau dürfen nicht durch künstliche Preisbarrieren verhindert werden.
- **CP13 - Marktanker sind keine Preisliste:** Öffentliche Preise dienen der Orientierung; sie sind wegen unterschiedlicher Scope-, Qualitäts- und Haftungsmodelle nicht eins zu eins vergleichbar.
- **CP14 - Marge folgt Standardisierung, nicht Qualitätsabbau:** Wirtschaftlichkeit entsteht durch Wiederverwendung, Automatisierung, bessere Daten und weniger Rework.
- **CP15 - Preislogik ist maschinenlesbar:** Angebote, Vertragsvarianten, Simulationen und Rechnungsprognosen basieren auf versionierten Pricing Rules.

3.2 Was ausdrücklich vermieden wird

- ein undurchsichtiger „Contact Sales“-Preis ohne erkennbare Logik,
- ein Sitzplatzmodell, das fachliche Nutzung künstlich einschränkt,
- ein Paket, das nur durch dauerhafte Zusatzverkäufe funktionsfähig wird,
- versteckte Onboarding-, Export- oder Offboarding-Gebühren,
- starre Bronze/Silber/Gold-Pakete ohne Bezug zum Kundenziel,
- SLA-Versprechen, die fachliche Qualität durch Geschwindigkeit ersetzen,
- automatische Upsells auf Basis sensibler Risikodaten ohne Governance,
- Gebühren für das bloße Abrufen eigener Daten,
- unechte Rabatte auf vorher künstlich erhöhte Listenpreise,
- Preisänderungen durch KI ohne menschliche kommerzielle Freigabe.

4. Kanonische Katalog- und Preisobjekte

4.1 Service Family

Eine **Service Family** gruppiert fachlich verwandte Services. Sie dient Navigation, Portfolio-Governance, Reporting und Skill-Zuordnung. Eine Familie ist noch nicht kaufbar.

4.2 Service Definition

Die Service Definition beschreibt Methode, Outcome, Standardumfang, Voraussetzungen, Work Packages, Deliverables, Quality Gates und zulässige Konfiguration. Sie wurde in Dokument 13 fachlich definiert.

4.3 Service Offer

Ein **Service Offer** ist eine kaufbare, versionierte Kombination aus:

- Service Definition und Version,
- Zielgruppe und geeigneten Zielprofilen,
- Service-Tiefe,
- Standard-Scope und Mengeneinheiten,
- Service-Level und Betriebszeit,
- enthaltenen Deliverables,
- Kundenmitwirkung und Annahmen,
- Preisformel und Mindestgebühr,
- Add-ons und Ausschlüssen,
- Vertragslaufzeit, Kündigung und Indexierung,
- Transition- und Exit-Regeln.

4.4 Package

Ein **Package** bündelt mehrere kompatible Service Offers für einen typischen Bedarf. Ein Paket ist ein Startpunkt, kein Zwang. Jedes Paket wird vor Aktivierung in einzelne Service Instances aufgelöst, damit Scope, Verantwortung und Preis je Service nachvollziehbar bleiben.

4.5 Price Book

Das **Price Book** ist ein versionierter Satz freigegebener Preisregeln. Es enthält:

- Währung, Region, Steuerlogik und Gültigkeit,
- Plattform- und Servicegrundpreise,
- Volumenbänder und Einheiten,
- Komplexitätsmodifikatoren,
- SLA- und Verfügbarkeitsaufschläge,
- Add-ons, Mindestmengen und Caps,
- Laufzeit- und Portfoliokonditionen,
- Reisekosten- und Drittanbieterregeln,
- Genehmigungsgrenzen und Ausnahmepfade.

4.6 Quote und Commercial Baseline

Ein **Quote** ist ein zeitlich begrenzter Angebotsstand. Nach Annahme entsteht eine **Commercial Baseline**, die mit Service Charter und Service Instance verknüpft ist. Jede Änderung erzeugt eine neue Version mit Delta zu Preis, Scope, Verantwortung, SLA und erwarteter Wirkung.

5. Servicefamilien und vollständiger Katalog

5.1 Katalogübersicht

ID	Servicefamilie	Primärer Outcome	Typischer Käufer
SF01	ISMS Governance & Leadership	Das ISMS besitzt klare Ziele, Entscheidungen, Rollen und einen belastbaren Betriebsrhythmus.	Executive Sponsor, CISO
SF02	Risk & Treatment	Risiken werden aktuell, erklärbar und wirksam behandelt.	CISO, ISMS Manager
SF03	Control Assurance & Evidence	Control-Design, Umsetzung, Betrieb und Wirksamkeit sind nachvollziehbar belegt.	ISMS Manager, Auditor
SF04	Policy & Documentation	Vorgaben sind aktuell, freigegeben, verständlich und tatsächlich anwendbar.	ISMS Manager, Legal, HR
SF05	Audit & Certification Readiness	Prüfungen werden planbar vorbereitet; Datenlücken und Findings werden früh gesteuert.	CISO, Audit Lead
SF06	Third-Party & Supply Chain	Kritische Lieferanten werden risikobasiert bewertet und überwacht.	Procurement, CISO
SF07	Threat, Vulnerability & Incident Governance	Technische Signale werden in geschäftliche Prioritäten und Governance übersetzt.	Security Lead, CISO
SF08	Awareness & Competence	Zielgruppen besitzen nachweisbare Fähigkeiten und angemessenes Sicherheitsverhalten.	HR, CISO

ID	Servicefamilie	Primärer Outcome	Typischer Käufer
SF09	Compliance & Regulatory Change	Relevante Anforderungen werden erkannt, bewertet und in konkrete Changes übersetzt.	Compliance, CISO
SF10	Reporting & Decision Support	Management erhält freigabefähige Entscheidungen, Reports und Wirkungssimulationen.	Vorstand, CISO
SF11	Virtual CISO / ISMS Office	Eine fehlende oder überlastete Sicherheitsführungsfunktion wird dauerhaft ergänzt.	Geschäftsführung
SF12	Platform & Data Operations	Plattform, Integrationen, Datenqualität und Automationen bleiben betriebsfähig.	Tenant Admin, ISMS Manager

5.2 Kanonische Service Offers

Offer-ID	Service Offer	Standardergebnis	Typischer Rhythmus
SO01	Managed ISMS Governance	Governance-Kalender, Zielsteuerung, Rollen, Management Review und Decision Records sind aktiv.	monatlich / quartalsweise
SO02	Managed Risk Management	Risikoregister, Reviews, Treatment und Eskalationen bleiben aktuell und entscheidungsfähig.	monatlich + eventbasiert
SO03	Managed Control Assurance	Priorisierte Controls werden geplant getestet, belegt und auf Wirksamkeit geprüft.	monatlich / quartalsweise
SO04	Managed Policy Lifecycle	Policies werden entworfen, abgestimmt, freigegeben, kommuniziert und rechtzeitig reviewed.	laufend + jährliche Zyklen
SO05	Managed Evidence Operations	Evidence Requests, Validierung, Ablaufdaten und Audit-Pakete werden gesteuert.	laufend / auditbezogen
SO06	Managed Audit Readiness	Auditroute, Readiness, Dry Runs, Evidence Packs, Termine und Findings werden orchestriert.	T-180 bis Post-Audit
SO07	Managed Supplier Risk	Kritische Lieferanten werden segmentiert, bewertet, nachverfolgt und eskaliert.	laufend / jährlich
SO08	Managed Threat & Vulnerability Governance	Relevante Threats und Schwachstellen werden auf Assets, Risiken, Controls und Maßnahmen gemappt.	wöchentlich + eventbasiert
SO09	Managed Findings & Exceptions	Findings, Ausnahmen, Akzeptanzen und Corrective Actions bleiben kontrolliert und nachvollziehbar.	laufend
SO10	Managed Awareness & Competence	Kampagnen, Rollenanforderungen, Teilnahme, Wirksamkeit und Verbesserungen werden gesteuert.	quartalsweise / jährlich
SO11	Regulatory Change Monitoring	regulatorische Änderungen werden bewertet, gemappt und in Change-Pakete übersetzt.	monatlich + eventbasiert
SO12	Executive Reporting & Board Advisory	Board- und Managementpakete werden aus freigegebenen Snapshots erzeugt und erläutert.	monatlich / quartalsweise
SO13	Virtual CISO / Strategic Security Office	Sicherheitsstrategie, Governance, Board-Kommunikation und priorisierte Roadmap werden geführt.	monatlicher Retainer
SO14	Platform & Integration Operations	Connectoren, Datenqualität, Rechte, Workflow-Packs und Reporting laufen kontrolliert.	laufend

Offer-ID	Service Offer	Standardergebnis	Typischer Rhythmus
SO15	ISMS Transition & Target Profile	Scope, Strategie-DNA, Baseline, Datenmodell, Roadmap und Operational Readiness werden aufgebaut.	einmalig / 6-16 Wochen

5.3 Angebotskarte je Service

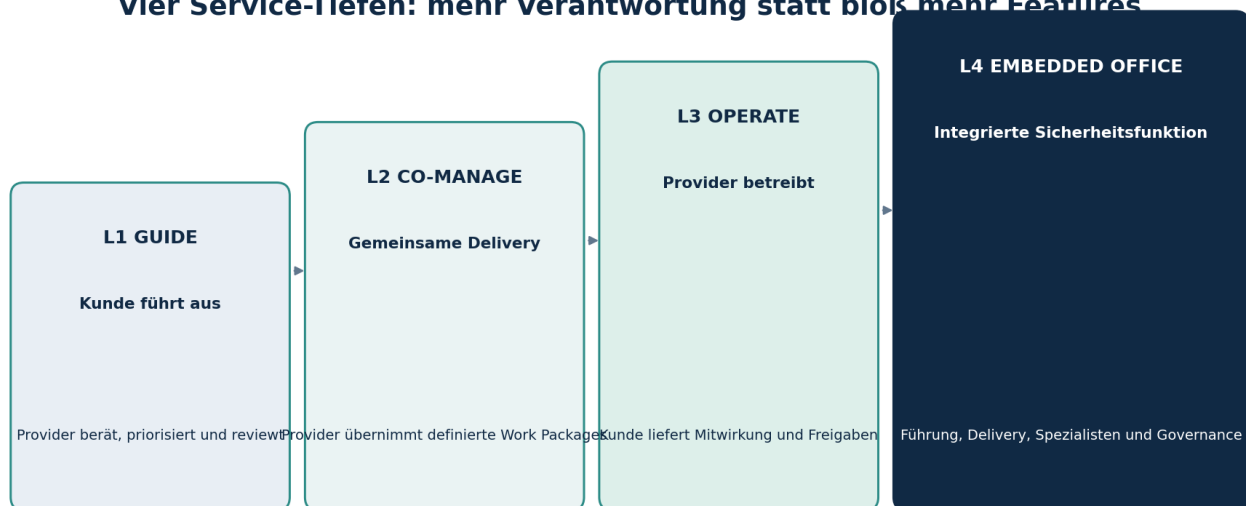
Jeder Service wird im Katalog mit derselben Struktur dargestellt:

1. Welches Problem löst der Service?
2. Welches Ergebnis kauft der Kunde?
3. Was ist konkret enthalten?
4. Was bleibt beim Kunden?
5. Welche Daten und Voraussetzungen werden benötigt?
6. Wie häufig und in welchem Service-Level wird gearbeitet?
7. Wie wird Qualität und Wirkung gemessen?
8. Wie wird der Preis gebildet?
9. Welche internen und externen Alternativen bestehen?
10. Wie kann der Service reduziert, erweitert oder beendet werden?

6. Service-Tiefen statt starrer Goldpakete

Die Plattform verwendet vier Service-Tiefen. Sie beschreiben Verantwortung und Delivery-Intensität, nicht Prestige.

Vier Service-Tiefen: mehr Verantwortung statt bloß mehr Features



Service-Tiefe verändert operative Verantwortung, Kapazitätsbindung, QA- und SLA-Bedarf - nicht nur die Zahl sichtbarer Funktionen.

Tiefe	Kurzbeschreibung	Kunde	Provider	Geeignet für
L1 Guide	Fachliche Führung und Qualitätssicherung	führt operativ aus	analysiert, berät, reviewt	reife interne Teams mit punktuelltem Bedarf
L2 Co-Manage	Gemeinsame operative Leistung	teilt Owner und Umsetzung	übernimmt definierte Work Packages	Teams mit Kapazitäts- oder Skilllücken
L3 Operate	Provider führt den laufenden Service	liefert Mitwirkung und Freigaben	plant, führt aus, berichtet und verbessert	ausgelagerte oder stark entlastete ISMS-Funktion
L4 Embedded Office	Integrierte Sicherheitsführungs- und Delivery-Funktion	behält Governance und Risikoentscheidung	stellt Team, Führung, Spezialisten und Betriebsmodell	komplexe, regulierte oder multi-entity Organisationen

Nicht jedes Service Offer unterstützt alle Tiefen. Beispielsweise kann Regulatory Change Monitoring auf L1 bis L3 angeboten werden; ein Embedded Office ist ein eigenständiges Gesamtmodell. Die Plattform zeigt deshalb pro Offer nur zulässige Konfigurationen.

7. Paketarchitektur

7.1 Paketprinzip

Pakete beschleunigen die Auswahl, ersetzen aber keine Charter. Jedes Paket enthält:

- ein Plattformniveau,
- eine Baseline an Governance- und Reporting-Leistungen,
- definierte Service Offers,
- Service-Tiefen und Leistungsbänder,
- ein Zielprofil und geeignete Kundensituationen,
- optionale Add-ons,
- klare Nicht-Enthalten-Punkte,
- eine illustrative Preisbandbreite.

7.2 Empfohlene Paketfamilien

Paket	Zielbild	Enthaltene Kern-Offer	Typische Tiefe
Navigate	Ein internes Team erhält Struktur, Priorität und seniorige Führung.	SO01, SO02, SO12, Plattform	L1 Guide
Co-Managed ISMS	Kunde und Provider betreiben das ISMS gemeinsam.	SO01-05, SO09, SO12, Plattform	L2 Co-Manage
Managed ISMS Office	Der laufende ISMS-Betrieb wird weitgehend übernommen.	SO01-05, SO07, SO09-12, SO14	L3 Operate
Embedded Security Office	Führung, Delivery und Spezialisten werden als integrierte Funktion bereitgestellt.	SO01-14 nach Scope	L4 Embedded Office
Audit Route	Ein konkretes Audit- oder Zertifizierungsziel wird kontrolliert vorbereitet.	SO05, SO06, SO09, SO12, optional SO15	Projekt + Retainer
Regulatory Route	NIS2-, DORA-, TISAX-, BSI- oder andere Zielroute wird operationalisiert.	SO01, SO02, SO03, SO11, SO12, optional Branchenpack	L1-L3

7.3 Paketmodularität

Der Konfigurator erlaubt:

- einzelne Offers hinzuzufügen oder zu entfernen,
- Service-Tiefen je Offer zu differenzieren,
- Mengengerüste und Frequenzen anzupassen,
- Add-ons für Regionen, Sprachen, Vor-Ort-Tage und Spezialisten zu wählen,
- ein Zielbudget vorzugeben und passende Routen zu vergleichen,
- intern zu erbringende Work Packages explizit zuzuordnen,
- erwartete Wirkung und Kapazitätsentlastung zu simulieren.

Ein Paket darf nicht aktiv werden, wenn eine entfernte Leistung eine zwingende Voraussetzung eines verbleibenden Offers verletzt.

8. Service-Level-Architektur

8.1 SLA, SLO und OLA

- **SLA:** vertragliches, kundenbezogenes Leistungsversprechen.
- **SLO:** intern oder extern kommuniziertes Ziel, das nicht zwingend kompensationspflichtig ist.
- **OLA:** interne Vereinbarung zwischen Delivery-, QA-, Plattform- oder Spezialistenteams.
- **KPI:** Messgröße; nicht jede KPI ist ein Leistungsversprechen.
- **Outcome Target:** erwartete Wirkung, die häufig von mehreren Parteien abhängt und deshalb kein reines SLA ist.

8.2 Messdimensionen

Dimension	Beispiel	Geeignet als SLA?
Acknowledgement	Anfrage wurde qualifiziert und ein Owner zugewiesen.	ja

Dimension	Beispiel	Geeignet als SLA?
Triage	Kritikalität, Scope und nächster Schritt wurden bestimmt.	ja
Start of Work	Bearbeitung hat begonnen.	teilweise
Delivery Time	vereinbartes Deliverable wurde bereitgestellt.	ja, wenn Voraussetzungen erfüllt
Review Time	Review oder Freigabe wurde durchgeführt.	ja, für Provideranteil
Data Freshness	Datenquelle oder Evidenz ist innerhalb eines Altersfensters.	ja, wenn Provider kontrolliert
Platform Availability	Plattform ist technisch verfügbar.	ja, in Dokument 18/19 zu konkretisieren
Finding Closure	Finding ist wirksam geschlossen.	meist nein, da Kundenabhängigkeit
Audit Success	Zertifizierung oder Audit ohne Finding.	nein
Risk Reduction	erwartete Risikowirkung ist eingetreten.	Outcome Target, kein reines SLA

8.3 Prioritätsklassen

Priorität	Definition	Beispiel
P1 Kritisch	unmittelbare erhebliche Geschäfts-, Compliance- oder Auditwirkung; zeitkritische Entscheidung erforderlich	kritischer Incident mit Governancebedarf, bevorstehender Auditblocker
P2 Hoch	erhebliche Wirkung, aber kontrollierbarer Zeitraum	Control-Ausfall, kritisches Finding, signifikante regulatorische Änderung
P3 Normal	reguläre Servicearbeit mit planbarer Frist	Policy Review, monatlicher Risk Run, Lieferantenbewertung
P4 Geplant	Roadmap-, Verbesserungs- oder Informationsanfrage	Template-Erweiterung, KPI-Anpassung, nicht dringende Analyse

8.4 Illustrative Service-Level-Bänder

Service-Level-Bänder: schnellere Reaktion braucht definierte Betriebs- und Kapazitätsreserven

	STANDARD Geschäftszeit	PRIORITY verlängerte Geschäftszeit	CRITICAL GOVERNANCE 24/7 nur für definierte P1	EMBEDDED kundenspezifisch / Follow-the-Sun
P1	4 Geschäftsstunden	2 Geschäftsstunden	60 Minuten	30-60 Minuten
P2	1 Geschäftstag	4 Geschäftsstunden	4 Stunden	2-4 Stunden
P3	2 Geschäftstage	1 Geschäftstag	1 Geschäftstag	gleicher Geschäftstag

Acknowledgement ist nicht gleich Lösung. Fachliche Lieferziele, Datenabhängigkeiten und Kundenmitwirkung werden separat vertraglich definiert.

Service-Level	Betriebszeit	P1 Acknowledgement	P2 Acknowledgement	P3 Acknowledgement	Standardkommunikation
Standard	Werktage, lokale Geschäftszeit	4 Geschäftsstunden	1 Geschäftstag	2 Geschäftstage	Plattform + E-Mail
Priority	verlängerte Geschäftszeit	2 Geschäftsstunden	4 Geschäftsstunden	1 Geschäftstag	Plattform + Teams/Slack optional

Service-Level	Betriebszeit	P1 Acknowledgement	P2 Acknowledgement	P3 Acknowledgement	Standardkommunikation
Critical Governance	24/7 Acknowledgement für definierte P1-Ereignisse	60 Minuten	4 Stunden	1 Geschäftstag	definierter Notfallkanal
Embedded	kundenspezifisch, ggf. Follow-the-Sun	30-60 Minuten	2-4 Stunden	gleicher Geschäftstag	integrierte Teamkanäle

Diese Werte sind **Designannahmen**, keine finalen Vertragszusagen. Für fachliche Deliverables werden gesonderte Lieferziele definiert. Die Uhr pausiert nur bei dokumentierter Kundenabhängigkeit, höherer Gewalt oder explizit freigegebener Ausnahme; sie darf nicht willkürlich angehalten werden.

8.5 Service Credits und Remedies

Service Credits sind nur für klar kontrollierbare, wiederholte und messbare Verletzungen geeignet. Bevorzugte Reihenfolge:

1. transparente Abweichung und Root-Cause-Analyse,
2. Recovery Plan und zusätzliche Qualitätskontrolle,
3. definierter Service Credit bei wiederholter Verletzung,
4. Sonderkündigungs- oder Reduktionsrecht bei systematischem Versagen.

Credits dürfen kein Ersatz für Problembeseitigung sein und keine sicherheitskritische Abweichung „abkaufen“.

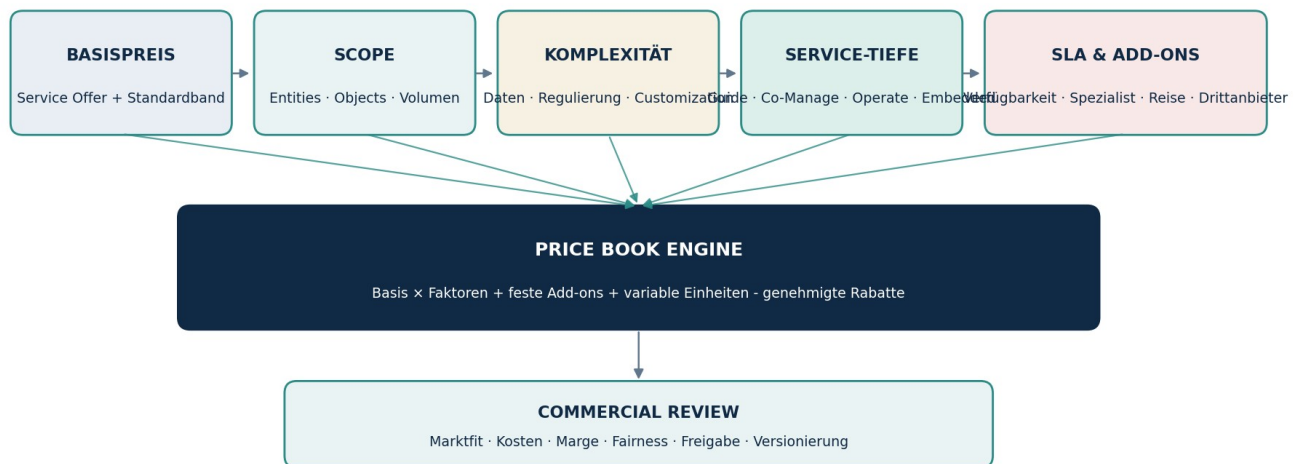
9. Preisverfassung und Preisformel

9.1 Preisbestandteile

Der Gesamtpreis eines Kunden setzt sich zusammen aus:

Gesamtpreis = Plattform + Transition + wiederkehrende Services + Add-ons + Usage/Mehrmenge + Reise/Drittanbieter - genehmigte Rabatte

Preislogik: nachvollziehbarer Vorschlag statt Black Box



9.2 Wiederkehrende Preisformel

Für eine Service Instance gilt konzeptionell:

Monatspreis = Basispreis × Scope-Faktor × Komplexitäts-Faktor × Service-Tiefen-Faktor × SLA-Faktor + feste Add-ons + variable Einheiten

Die Formel ist kein automatischer Marktpreisgenerator. Sie erzeugt einen nachvollziehbaren Vorschlag innerhalb freigegebener Price-Book-Grenzen. Außerhalb der Grenzen ist eine kommerzielle und fachliche Freigabe erforderlich.

9.3 Basiskostenmodell

Vor Freigabe eines Price Books muss jedes Offer mindestens folgende Kostenkomponenten abdecken:

- erwartete Delivery-Stunden nach Rolle und Skill,
- Quality Review und Management Oversight,

- Plattform- und Infrastrukturkosten,
- Integrations- und Supportanteil,
- Standardisierung, Methodenpflege und Dokumentation,
- Vertrieb, Vertrags- und Service-Governance,
- Reise- und Vor-Ort-Risiko,
- erwartetes Rework und Datenqualitätsrisiko,
- Kapazitäts- und Eskalationsreserve,
- angemessene Zielmarge.

Zielmargen werden nicht in diesem Dokument verbindlich festgelegt. Sie sind eine kommerzielle Governanceentscheidung und müssen nach Servicefamilie, Reife, Automatisierungsgrad und Haftungsprofil differenziert werden.

10. Preistreiber und Mengeneinheiten

10.1 Scope-Treiber

- Zahl der rechtlichen Einheiten und Mandantenbereiche,
- Regionen, Sprachen und Zeitzonen,
- Mitarbeitenden- und Nutzerbänder,
- Anzahl kritischer Geschäftsprozesse,
- Anzahl relevanter Assets, Systeme und Datenquellen,
- Zahl der Controls, Frameworks und regulatorischen Zielprofile,
- Zahl der Lieferanten oder Assessments,
- Zahl der Audits, Reports oder Management Reviews,
- Zahl aktiver Risiken, Findings und Maßnahmen,
- Anzahl und Frequenz von Service Runs.

10.2 Komplexitäts-Treiber

Treiber	Niedrig	Mittel	Hoch
Datenqualität	integrierte, aktuelle Quellen	teilweise manuell	fragmentiert, widersprüchlich
Organisation	eine Einheit, klare Owner	mehrere Bereiche	Multi-Entity, global, Matrixorganisation
Regulierung	ein Zielprofil	mehrere Frameworks	stark reguliert, länderübergreifend
Customization	Standardworkflow	parametrisierte Varianten	viele genehmigte Ausnahmen
Service-Tiefe	Guide	Co-Manage	Operate/Embedded
Governance	wenige Freigaben	mehrere Gremien	komplexe Board-, Audit- und Regulatorikpfade
Vor-Ort-Anteil	remote	einzelne Termine	häufige Standorte und Reisen
Volatilität	stabil	saisonal	häufige Incidents, M&A, Transformation

10.3 Nicht geeignete alleinige Preistreiber

- reine User Seats,
- Zahl gespeicherter Dokumente,
- Zahl einzelner Kommentare oder Tasks,
- Zahl der Logins,
- ein pauschaler Prozentsatz des Kundenumsatzes,
- ausschließlich der aktuelle Risikoscore.

Seats können für Lizenzadministration relevant sein, dürfen aber nicht das zentrale Wert- oder Kostensignal der Plattform sein.

11. Plattformlizenz

11.1 Lizenzprinzip

Die Plattformlizenz wird primär nach Mandanten-/Entity-Komplexität und Funktionsniveau gebildet. Alle Rollen, die für einen ordnungsgemäßen Prozess benötigt werden, sollen ohne künstliche Seat-Knappheit teilnehmen können. Enthaltene Nutzerbänder dienen technischer Skalierung, nicht der Verhinderung von Collaboration.

11.2 Illustrative Plattformbänder

Plattformniveau	Geeigneter Scope	Illustratives Preisband pro Monat, exkl. USt.	Enthaltene Kernfunktionen
Core	eine Einheit, begrenzter Scope	EUR 500-1.500	ISMS-Kern, Digital Twin Light, Tasks, Policies, Standardreports
Professional	mittlerer Scope, mehrere Frameworks	EUR 1.500-4.000	voller Digital Twin, Decision Center, Reporting Engine, Automationen
Enterprise	Multi-Entity, komplexe Rechte und Integrationen	EUR 4.000-12.000+	Multi-Tenancy, erweiterte APIs, Portfolios, Branding, Enterprise Governance
Provider / Practice	Beratungs- oder MSP-Betrieb über viele Mandanten	individuelle Plattform- und Portfoliovereinbarung	Provider Mission Control, Template Library, Service Factory, Portfolio Analytics

Diese Bänder sind Produktannahmen. Öffentliche Marktangebote reichen von niedrigpreisigen GRC-Tools im zweistelligen bis niedrigen dreistelligen Monatsbereich bis zu Enterprise-Angeboten mit individueller Preisbildung. Die eigene Plattform positioniert sich nicht als reines SMB-Checklistentool, sondern als Enterprise- und Managed-Service-Betriebssystem.

11.3 Plattform-Add-ons

- zusätzliche rechtliche Einheit oder isolierter Datenraum,
- zusätzliche Region oder Datenresidenz,
- Premium-Connector oder kundenspezifische Integration,
- zusätzliche Brand-/Report-Template-Familie,
- erweiterte API- oder Exportvolumen,
- Sandbox und zusätzliche Testumgebung,
- regulatorisches oder branchenspezifisches Content Pack,
- erweiterte Aufbewahrung oder Archivierung,
- Premium Support und technische Rufbereitschaft.

12. Illustrative Managed-Service-Pakete

Die folgenden Preise sind **keine realen Angebote** und keine internen Preise einer bestimmten Beratung. Sie sind synthetische Demo-Bänder, abgeleitet aus öffentlich sichtbaren Software- und vCISO-Marktankern sowie dem deutlich breiteren Scope dieser Plattform.

12.1 Navigate

Ziel: Seniorige Orientierung und verlässliche Governance bei starker interner Ausführung.

- Plattform Professional,
- monatlicher Governance- und Risk Review,
- quartalsweiser Executive Report,
- Decision Cards und priorisierte Zielroute,
- begrenzte Policy- und Evidence-Reviews,
- Service-Level Standard.

Illustratives Band: EUR 3.500-6.500 pro Monat **Transition:** EUR 7.500-15.000 einmalig

12.2 Co-Managed ISMS

Ziel: Gemeinsamer Betrieb mit klar geteilter operativer Verantwortung.

- Plattform Professional oder Enterprise,
- Managed Governance, Risk, Policy, Evidence und Findings,
- monatliche Service Runs und quartalsweises Management Review,
- definierte Work Packages und Quality Gates,
- Reporting und Auditkalender,
- Service-Level Standard oder Priority.

Illustratives Band: EUR 7.500-15.000 pro Monat **Transition:** EUR 15.000-30.000 einmalig

12.3 Managed ISMS Office

Ziel: Weitgehende operative Übernahme des ISMS-Regelbetriebs.

- Plattform Enterprise,
- Governance, Risk, Control Assurance, Policy, Evidence, Supplier Risk, Findings und Reporting,
- Portfolio- und Service Health,
- wiederkehrende Management- und Auditpakete,
- definierter Specialist Pool,
- Service-Level Priority.

Illustratives Band: EUR 15.000-30.000 pro Monat **Transition:** EUR 25.000-50.000 einmalig

12.4 Embedded Security Office

Ziel: Integrierte virtuelle Sicherheitsführungs- und Delivery-Funktion für komplexe Organisationen.

- benannter vCISO / Engagement Lead,
- operatives ISMS-Team und Specialist Pool,
- Multi-Entity- und Multi-Framework-Betrieb,
- Board Advisory, Incident Governance und Transformation,
- kundenspezifische Verfügbarkeit und Service-Level,
- erweiterte Onsite-, Reise- und Regionsleistung.

Illustratives Band: EUR 30.000-75.000+ pro Monat **Transition:** kundenspezifisch, typischerweise ab EUR 40.000

12.5 Audit Route

Ziel: Kontrollierte Vorbereitung auf Zertifizierung, Überwachungsaudit oder regulatorische Prüfung.

- Baseline und Readiness Route,
- Evidence Operations,
- Dry Run und Finding Management,
- Audit Pack, Management Brief und Präsentation,
- optional Vor-Ort-Unterstützung.

Illustratives Projektband: EUR 15.000-60.000 je nach Scope; komplexe Multi-Entity-Programme darüber. **Optionaler laufender Retainer:** EUR 3.000-12.000 pro Monat.

13. Illustrative Einzelservice-Bänder

Service Offer	Illustratives monatliches Band	Primäre Mengentreiber
Managed ISMS Governance	EUR 2.000-6.000	Gremien, Entities, Frequenz, Executive Support
Managed Risk Management	EUR 2.500-8.000	aktive Risiken, Reviews, Business Units, Service-Tiefe
Managed Control Assurance	EUR 3.000-12.000	Controls, Testfrequenz, Evidence, QA-Tiefe
Managed Policy Lifecycle	EUR 1.500-5.000	Policy-Anzahl, Sprachen, Freigabestufen
Managed Evidence Operations	EUR 2.000-8.000	Evidence Objects, Systeme, Auditkalender
Managed Supplier Risk	EUR 1.500-10.000	Lieferantenband, Kritikalität, Fragebögen, Reviews
Threat & Vulnerability Governance	EUR 2.500-10.000	Assets, Quellen, Ereignisvolumen, Triage-Level
Regulatory Change Monitoring	EUR 1.500-6.000	Rechtsräume, Frameworks, Change-Frequenz
Executive Reporting & Board Advisory	EUR 1.500-5.000	Reportfrequenz, Gremien, Narrative, Simulationen
Virtual CISO / Security Office	EUR 5.000-25.000+	Tage/Monat, Seniorität, Haftungsprofil, Verfügbarkeit
Platform & Integration Operations	EUR 1.000-8.000	Connectoren, Datenvolumen, Custom Workflows, Supportlevel

Einzelservice-Bänder sind nicht additiv zu verstehen. In Paketen werden gemeinsame Governance, Plattform, Reporting, QA und Delivery-Artefakte dedupliziert.

14. Add-ons und einmalige Leistungen

14.1 Einmalige Leistungen

- ISMS Baseline und Strategy-DNA Workshop,
- Scope- und Zielprofil-Design,
- Datenmigration und Initial Mapping,
- Connector-Setup und Integrationstest,
- Policy- oder Control-Library-Migration,
- Framework- oder Branchenpack-Konfiguration,
- Audit Dry Run,
- Incident Tabletop,
- Management- oder Board-Workshop,
- Handover, Internalisierung oder Exit-Projekt.

14.2 Spezialisten-Add-ons

- OT-/ICS-Security,
- Cloud Security Architecture,
- IAM/PAM,
- DORA/NIS2/BSI/TISAX-Fachberatung,
- Datenschutz und Legal Review,
- Penetration Test oder Red Team über getrennten Service,
- Forensik und Incident Response,
- Resilience/BCM,
- M&A und Due Diligence.

Spezialisten dürfen nur dann als wiederkehrender Bestandteil kalkuliert werden, wenn Bedarf und Frequenz planbar sind. Ansonsten werden sie als freigegebene Usage- oder Projektleistung behandelt.

15. Öffentliche Marktanker und Interpretation

15.1 Beobachtete öffentliche Preispunkte, Stand Juli 2026

Anbieter / Angebot	Öffentlicher Preisanker	Einordnung
isopilot	EUR 99-879/Monat nach Unternehmensgröße; Advisory EUR 99/Stunde	niedrigpreisige ISO-Software mit optionaler Beratung
Qontrol	EUR 69/Monat für Plattform, optionale Nutzergebühr	SMB-/Mid-Market-GRC-Basis, nicht mit Enterprise Managed Service vergleichbar
vCISO Lite	USD 299-1.499/Monat	softwarezentrierte, standardisierte vCISO-/Reporting-Stufen
vCISO.com	USD 5.000/Monat Strategic; USD 24.000 für 90-Tage-Foundation; öffentlich genannte Marktspanne USD 3.000-15.000/Monat	senioriger Retainer und produktisierte Projekte
Cybervize	veröffentlichte DACH-Spanne EUR 2.500-15.000/Monat; Service ab EUR 3.600/Monat	europäischer vCISO-Marktanker
vCISO-EU	EUR 5.000, EUR 12.000 und EUR 25.000+/Monat	gestufte europäische Security-Office-Angebote

15.2 Schlussfolgerungen

- Softwarepreise allein liegen deutlich unter umfassenden Managed-Service-Retainern.
- Transparente Low-End-Angebote besitzen meist engeren Scope, weniger Seniorität oder stärkere Standardisierung.
- Seniorige vCISO-Retainer bewegen sich öffentlich häufig im mittleren vier- bis niedrigen fünfstelligen Monatsbereich.
- Embedded oder enterpriseweite Leistungen liegen oberhalb klassischer vCISO-Retainer und werden meist individuell angeboten.
- Ein Managed ISMS mit Plattform, operativer Delivery, QA, Reporting, Auditunterstützung und Multi-Entity-Scope ist nicht mit einem reinen Compliance-SaaS-Preis vergleichbar.
- Öffentliche Marktanker sprechen für eine modulare Architektur mit klarer Trennung zwischen Plattform, Transition, Retainer und Zusatzleistungen.

15.3 Grenzen der Marktanker

Öffentliche Preise unterscheiden sich erheblich nach Region, Branche, Unternehmensgröße, Seniorität, Haftung, Reaktionszeit, enthaltenen Stunden, Toolkosten und Auditumfang. Viele Enterprise-Anbieter veröffentlichen keine Preise. Deshalb werden die Bänder in diesem Dokument als **begründete Annahmen für Produktdesign und Demo** verwendet, nicht als belastbare Marktpreisstudie oder verbindliche Angebotsgrundlage.

16. Kunden-Business-Case

16.1 Vergleichsoptionen

Die Plattform zeigt mindestens drei Optionen:

- 1. Internal Build:** Personal einstellen, Tools beschaffen und Prozesse intern aufbauen.
- 2. Co-Managed / Managed Service:** Plattform und externe Delivery kombinieren.
- 3. Nichtstun / verzögern:** Kosten und Risiko der Verschiebung sichtbar machen.

16.2 Nutzenkomponenten

- vermiedene oder verzögerte Vollzeitstellen,
- geringere Zeit für Reporting, Evidence und Koordination,
- schnellere Audit- und Kundenanfragen,
- reduzierte Rework- und Finding-Kosten,

- bessere Priorisierung von Sicherheitsinvestitionen,
- geringere Abhängigkeit von Einzelpersonen,
- schnellere Zielerreichung,
- höhere Entscheidungsgeschwindigkeit,
- messbare Kapazitätsentlastung,
- vermiedene Reisekosten durch intelligente Remote-/Onsite-Planung.

16.3 Business-Case-Formeln

Jahreskosten Managed Service = 12 × Monatsretainer + Transition + Add-ons + Reise + Drittanbieter

Interne Vergleichskosten = Personallvollkosten + Toolkosten + Recruiting + externe Spezialisten + Rework + Managementaufwand

Nettonutzen = vermiedene Kosten + Produktivitätsgewinn + quantifizierbare Risikowirkung - Managed-Service-Gesamtkosten

Risikowirkung wird nur aufgenommen, wenn Annahmen, Bandbreiten und Unsicherheit transparent sind. Die Plattform darf keine scheinpräzise ROI-Zahl aus einem abstrakten Risikoscore ableiten.

17. Provider-Unit-Economics

17.1 Steuerungsgrößen

- Annual Recurring Revenue und Monthly Recurring Revenue,
- Gross Margin je Service Family, Offer und Service Instance,
- Delivery Cost und Cost-to-Serve,
- Senior-/Specialist-Anteil,
- Automatisierungs- und Wiederverwendungsquote,
- Revenue per Delivery FTE,
- Utilization und effektive Kapazität,
- Rework, Blocker und ungeplante Mehrarbeit,
- Travel-to-Revenue und Onsite-Effizienz,
- Renewal, Expansion, Reduction und Churn,
- Value Realization und Kundenzufriedenheit.

17.2 Margin Guardrails

Ein Service wird als wirtschaftlich gefährdet markiert, wenn:

- Ist-Aufwand wiederholt das Leistungsband überschreitet,
- Datenqualität dauerhaft manuelle Bereinigung erfordert,
- nicht gebuchte Sonderleistungen zum Normalfall werden,
- Senior- oder Spezialistenanteil strukturell höher ist als kalkuliert,
- Reise- und Vor-Ort-Aufwand den Plan überschreitet,
- SLA oder Quality Gates nur durch Überstunden gehalten werden,
- Customization Wiederverwendung verhindert,
- Kundennutzen trotz hoher Delivery-Kosten nicht bestätigt wird.

Korrekturpfade sind Workflow-Verbesserung, Datenintegration, Scopeklärung, Service-Level-Anpassung, Paketwechsel, Preisänderung zur Verlängerung oder geordnete Beendigung. Qualitätsabbau ist kein zulässiger Margin-Hebel.

18. Rabatte, Laufzeit und Indexierung

18.1 Zulässige Rabattarten

- Laufzeitrabatt für jährliche oder mehrjährige Bindung,
- Portfolio-/Multi-Entity-Rabatt bei echter Wiederverwendung,
- Pilot- oder Design-Partner-Kondition mit klarer Gegenleistung,
- Ramp-up-Kondition während Transition,
- gemeinnützige oder strategische Sonderkondition nach Freigabe,
- Bundle-Rabatt für deduplizierte gemeinsame Leistungen.

18.2 Rabattregeln

- Rabattgrund und Genehmiger werden gespeichert.
- Rabatt besitzt Ablaufdatum und Verlängerungsregel.
- Standardrabatt verändert keine SLA-, QA- oder Security-Anforderung.
- Portfoliorabatt ist nur zulässig, wenn tatsächliche Skaleneffekte bestehen.
- Ein Pilotpreis darf nicht als dauerhafter Referenzpreis missverstanden werden.
- Die Plattform zeigt Listenpreis, Rabatt, Nettopreis und Gegenleistung getrennt.

18.3 Indexierung

Preisindexierung kann an einen transparenten, vertraglich definierten Index oder eine feste Obergrenze gekoppelt werden. Sie erfolgt frühestens zur Verlängerung oder zu vereinbarten Jahrestermen. Wesentliche Scope- oder Service-Level-Änderungen werden über Change statt Indexierung behandelt.

19. Mehrmengen, Fair Use und Change Requests

19.1 Leistungsband statt Minutenabrechnung

Ein Retainer enthält ein erwartetes Leistungsband, beispielsweise Anzahl Risk Reviews, Service Runs, Board Reports, Supplier Assessments oder Specialist Days. Die Plattform zeigt:

- vereinbarte Baseline,
- aktuelle Nutzung,
- Prognose bis Periodenende,
- drohende Mehrmenge,
- verfügbare Priorisierungsoptionen,
- erwarteten Preis einer Änderung.

19.2 Overage-Regeln

- kleine Schwankungen werden durch Fair-Use-Band abgefangen,
- wiederkehrende Überschreitung führt zu Review des Baselinescopes,
- unvorhersehbare P1-Ereignisse besitzen vorab definierte Surge-Regeln,
- zusätzliche Leistung benötigt bei Überschreiten einer Genehmigungsgrenze Zustimmung,
- nicht verbrauchte Mengen werden nur übertragen, wenn das Offer dies ausdrücklich vorsieht,
- automatische Overage-Abrechnung ohne Vorwarnung ist nicht zulässig.

19.3 Change-Kategorien

Kategorie	Beispiel	Kommerzielle Behandlung
Konfiguration	Schwellenwert oder Berichtstermin	innerhalb Band, sofern Aufwand gering
Mehrmenge	zusätzliche Lieferanten oder Controls	Volumenband oder Usage
Scope Change	neue Entity, Region oder Framework	neue Baseline / Change Offer
Service-Level Change	Priority statt Standard	SLA-Faktor ab Wirksamkeitsdatum
Custom Build	neuer Connector oder Sonderworkflow	separates Projekt + Betriebskosten
Emergency Surge	Incident oder dringender Auditblocker	vorab definierte Surge Rate oder Notfallpaket

20. Reise, Vor-Ort und Drittanbieter

20.1 Reiseprinzipien

- Remote ist Standard, wenn Ergebnis und Qualität nicht leiden.
- Vor-Ort-Leistung wird fachlich begründet und im Kalender sichtbar geplant.
- Reisezeit und Reisekosten werden getrennt ausgewiesen.
- Mehrere Termine können geografisch und zeitlich gebündelt werden.
- Nachhaltigkeit, Sicherheit und Arbeitszeit werden berücksichtigt.
- Kein Berater soll durch unrealistische Reiseplanung SLA-Versprechen halten müssen.

20.2 Illustrative Behandlung

- genehmigte Reiseauslagen als Pass-through gegen Beleg oder vereinbarte Pauschale,
- Reisezeit je nach Paket teilweise enthalten, rabattiert oder als definierte Einheit,
- Vor-Ort-Tag mit Rollen-/Skill-basiertem Preis,
- kurzfristige Umbuchung nach klarer Stornoregel,
- internationale Reise, Visum und Sicherheitsanforderungen als Sonderleistung.

20.3 Drittanbieter

Zertifizierungsstelle, Penetrationstest, Trainingsplattform, Threat Feed, Rechtsberatung oder Spezialsoftware werden als Drittanbieter transparent getrennt. Der Provider darf Pass-through-Kosten, Management Fee oder gebündelten Preis verwenden, muss aber Modell und Verantwortungsgrenze offenlegen.

21. Preis- und Angebots-UX

21.1 Guided Configurator

Der Konfigurator fragt nicht zuerst nach Budget, sondern nach:

- Ziel und Zeitrahmen,
- aktueller Reife und Datenlage,
- interner Kapazität und Skills,
- gewünschter Verantwortungsteilung,
- Entities, Regionen und Frameworks,
- Reporting-, Audit- und Service-Level-Bedarf,
- Vor-Ort- und Spezialistenbedarf.

Danach zeigt er drei sinnvolle Routen: intern geführt, co-managed und weitgehend managed. Jede Route enthält Preisband, erwartete Wirkung, Voraussetzungen, Risiken und nicht enthaltene Leistungen.

21.2 Commercial Transparency Panel

Jeder Kunde sieht:

- aktuelle Commercial Baseline,
- monatliche und jährliche Prognose,
- Preisbestandteile und Mengentreiber,
- tatsächliche Nutzung und Fair-Use-Status,
- genehmigte und vorgeschlagene Changes,
- Rabatte und Ablaufdaten,
- Reise- und Drittanbieter-Kosten,
- gemessene Servicewirkung und Value Ledger,
- nächste Verlängerung oder Kündigungsfrist.

21.3 Opportunity Card

Eine Service Opportunity Card enthält:

- beobachtetes Problem und Datenquelle,
- erwartete Wirkung und Confidence,
- interne Alternative,
- Managed-Service-Option,
- Nichtstun-Option,
- Preisband und relevante Annahmen,
- benötigte Freigaben,
- Verbot der automatischen Buchung.

22. Renewal, Expansion, Reduction und Exit

22.1 Renewal Review

Spätestens 90 Tage vor Verlängerung prüft die Plattform:

- Outcome und bestätigten Wert,
- Service Health und SLA,
- Nutzung und Scope-Fit,
- Preis- und Kostenentwicklung,
- offene Rework- oder Datenprobleme,
- gewünschte Internalisierung oder Erweiterung,
- geplante Zieländerungen.

22.2 Expansion

Expansion wird nur empfohlen, wenn ein belegtes Problem und ein sinnvoller Outcome existieren. Wiederholte Mehrmenge, neue Regulierung oder fehlende interne Kapazität können Trigger sein. Umsatzpotenzial allein ist kein gültiger Trigger.

22.3 Reduction und Internalisierung

Kunden können Service-Tiefe reduzieren, einzelne Offers entfernen oder Work Packages internalisieren. Preis, Verantwortung, SLA und verbleibende Abhängigkeiten werden vor Freigabe simuliert. Handover kann als zeitlich begrenztes Transition Offer angeboten werden.

22.4 Exit

Es gibt keine Gebühren für den Standardexport vereinbarter Kundendaten. Zusätzliche Migration, Transformation oder Handover-Beratung kann als klarer Service bepreist werden. Offene Pre-Authorizations, Usage und Drittanbieter-Kosten werden transparent abgeschlossen.

23. Governance, Unabhängigkeit und ethische Grenzen

- Serviceverkauf und unabhängige Audit-/Zertifizierungsentscheidung müssen organisatorisch getrennt sein.
- Die Plattform darf nicht behaupten, dass der Kauf eines Services eine Zertifizierung oder regulatorische Akzeptanz garantiert.
- Opportunity Scores dürfen sensible Risiken nicht manipulativ monetarisieren.
- Empfehlung, Preis und fachliche Begründung müssen reviewbar sein.
- Kunden dürfen eine Empfehlung ablehnen, ohne dass Risikodaten verändert oder versteckt werden.
- Interessenkonflikte, Referral Fees und Drittanbieterprovisionen werden offengelegt.
- Preisentscheidungen auf Basis geschützter Merkmale oder unzulässiger Kundendaten sind verboten.
- Automatisierte Preisexperimente benötigen Governance, Fairness- und Rechtsprüfung.

24. End-to-End-Szenarien

24.1 Kunde wählt Co-Managed ISMS

1. Strategie-DNA zeigt Zielreife 3, begrenzte interne Kapazität und ein Audit in zwölf Monaten.
2. Konfigurator vergleicht Navigate, Co-Managed und Managed ISMS Office.
3. Kunde sieht Scope, Outcome, Mitwirkung, Preisband und erwartete Entlastung.
4. Co-Managed wird mit SO01 bis SO05 und Priority-SLA ausgewählt.
5. Price Book berechnet Baseline; individuelle Ausnahme benötigt Freigabe.
6. Transition, Charter und Commercial Baseline werden gemeinsam bestätigt.
7. Nutzung, Wert und drohende Mehrmengen werden laufend sichtbar.
8. Renewal Review zeigt, dass Supplier Risk als neues Offer fachlich sinnvoll ist.

24.2 Audit Route mit Vor-Ort-Tagen

1. T-150 erkennt die Plattform erhöhte Evidence-Lücke.
2. Audit Route wird mit Dry Run, vier Vor-Ort-Tagen und Executive Report konfiguriert.
3. Reisezeit, Auslagen und Stornoregel werden separat gezeigt.
4. Nach Scope-Freigabe entstehen Audit-Runs und Service-Level.
5. Eine zusätzliche Entity löst einen Change mit Preisdelta aus.
6. Nach Audit endet das Projekt; laufende Evidence Operations bleiben optional.

24.3 Mehrmenge im Supplier Risk Service

1. Vertrag umfasst 100 Lieferantenbewertungen pro Jahr mit Fair-Use-Band.
2. Akquisition erhöht Prognose auf 160.
3. Plattform warnt früh und zeigt drei Optionen: priorisieren, Volumenband erhöhen, temporäres Projekt.
4. Kunde wählt zusätzliches Volumenband ab nächstem Quartal.
5. Baseline, Preis und Kapazitätsplan werden versioniert.

24.4 Service wirtschaftlich gefährdet

1. Datenqualität erzeugt über drei Monate hohes manuelles Rework.
2. Margin Guardrail und Service Health wechseln auf at risk.
3. Root Cause zeigt fehlende Integration und unklare Evidence Owner.
4. Optionen: Connector-Projekt, Scope-Reduktion oder Preisanpassung zur Verlängerung.
5. Kunde genehmigt Connector und Rollenbereinigung.
6. Nach zwei Runs sinkt Rework; Preis bleibt unverändert.

24.5 Internalisierung

1. Kunde baut internes Risk-Team auf.
2. Managed Risk Management wechselt von L3 Operate zu L1 Guide.
3. Handover, Shadowing und Quality Gate werden als Transition konfiguriert.
4. Monatspreis sinkt nachvollziehbar; Plattform und Board Reporting bleiben bestehen.
5. Service kann später ohne Datenverlust wieder erhöht werden.

25. Demo-Spezifikation

Der Demonstrator muss mindestens folgende Szenen zeigen:

1. Servicekatalog mit Familien, Outcomes und verständlichen Angebotskarten.
2. Vergleich von Navigate, Co-Managed und Managed ISMS Office.
3. Konfigurator mit Ziel, Scope, Service-Tiefe, SLA und Preisprognose.
4. Erklärung, warum der Preis steigt oder sinkt.
5. öffentliche Marktanker als Informationspanel, klar als nicht direkt vergleichbar markiert.
6. Commercial Baseline eines synthetischen Kunden.
7. Fair-Use- und Mehrmengenprognose.
8. Change Request für zusätzliche Entity oder höheres SLA.
9. Reise- und Vor-Ort-Kosten in Audit Route.
10. Opportunity Card mit interner, Managed-Service- und Nichtstun-Option.
11. Value Ledger neben Preis und Nutzung.
12. Renewal Review mit Expansion, Reduction und Internalisierung.

Alle Namen, Preise, Rabatte, Service-Level, Kosten und Unternehmensdaten im Demonstrator sind synthetisch. Sie müssen realistisch, aber eindeutig als Demo gekennzeichnet sein.

26. Akzeptanzkriterien

- Jeder kaufbare Service besitzt Outcome, Scope, Voraussetzungen, Mitwirkung, Deliverables, Service-Level, Preislogik und Exit-Regel.
- Plattform, Transition, Service, Usage, Reise und Drittanbieter sind getrennt ausgewiesen.
- Preisänderungen sind versioniert und besitzen Wirksamkeitsdatum.
- Kein Paket garantiert Zertifizierung oder vollständige Sicherheit.
- Kunden sehen Preisband und zentrale Preistreiber vor einer Kontaktaufnahme oder spätestens im geführten Konfigurator.
- Mehrmengen erzeugen Warnung und Optionen vor automatischer Abrechnung.
- Service Credits gelten nur für kontrollierbare Messgrößen.
- Ein Service kann erweitert, reduziert, pausiert, internalisiert und beendet werden.
- Opportunity Cards enthalten interne und Nichtstun-Option.
- Marktanker werden mit Quelle, Datum und Vergleichsgrenze dokumentiert.
- Jede Commercial Baseline ist mit Service Charter und Price-Book-Version verknüpft.
- Unit Economics dürfen nicht durch Verringerung verbindlicher Quality Gates verbessert werden.
- Reise- und Drittanbieter-Kosten sind vor Freigabe erkennbar.
- Angebote und Preislogik sind exportierbar und auditierbar.

27. Festgelegte Entscheidungen

ID	Entscheidung
D14-01	Plattformlizenz, Transition, Managed Services, Usage, Reise und Drittanbieter werden separat ausgewiesen.
D14-02	Service Offers werden nach Outcome und Service-Tiefe, nicht primär nach Beraterstunden verkauft.
D14-03	Pakete sind konfigurierbare Startpunkte und werden in einzelne Service Instances aufgelöst.
D14-04	Vier Service-Tiefen Guide, Co-Manage, Operate und Embedded beschreiben Verantwortung und Delivery-Intensität.
D14-05	Preise werden aus einem versionierten, maschinenlesbaren Price Book abgeleitet.
D14-06	User Seats sind kein alleiniger zentraler Preistreiber.
D14-07	Mehrmengen werden vor Abrechnung prognostiziert und benötigen oberhalb einer Grenze Freigabe.
D14-08	Zertifizierung, Audit-Erfolg und vollständige Risikoreduktion sind keine garantierten SLA-Ergebnisse.
D14-09	Service Opportunity Cards zeigen interne, Managed-Service- und Nichtstun-Option.
D14-10	Standardexport eigener Kundendaten wird nicht durch Exit-Gebühren blockiert.
D14-11	Alle derzeitigen Preisbänder sind synthetische Designannahmen, keine realen Angebote oder internen Preislisten.
D14-12	Kunden können Service-Tiefe und Module über kontrollierte Changes erhöhen oder reduzieren.
D14-13	Preis- und Leistungsänderungen sind historisiert, freigabepflichtig und nicht rückwirkend.
D14-14	Margin-Verbesserung darf Quality Gates, Security oder notwendige Reviewtiefe nicht still reduzieren.
D14-15	Der Demonstrator enthält realistische Preis-, Paket-, SLA- und Change-Szenarien mit klarer Demo-Kennzeichnung.

28. Begründete Annahmen

- Der primäre Zielmarkt liegt zunächst bei mittleren bis großen Organisationen und Beratungs-/Managed-Service-Providern.
- Kunden akzeptieren eine getrennte Plattform- und Servicegebühr, wenn Scope und Nutzen transparent sind.
- Ein beträchtlicher Teil der Delivery lässt sich standardisieren, ohne kundenspezifische Zielprofile aufzugeben.
- Öffentliche vCISO-Preise sind ein brauchbarer Unteranker, aber kein vollständiger Vergleich für Managed ISMS.
- Enterprise- und Multi-Entity-Angebote benötigen individuelle Preisbildung innerhalb freigegebener Regeln.
- Jährliche Laufzeiten sind für planbare Services wahrscheinlich sinnvoller als vollständig monatliche Kündbarkeit.
- Ein geführter Konfigurator erhöht Vertrauen, wenn er nicht als aggressiver Upsell gestaltet ist.
- Wertmessung und transparente Nutzung verbessern Renewal- und Expansion-Entscheidungen.
- Nicht jeder Kunde möchte vollständige Preistransparenz öffentlich; ein plausibles Band vor dem Verkaufsgespräch bleibt dennoch sinnvoll.
- Service-Level müssen je Region, Sprache und Betriebsmodell differenzierbar sein.

29. Offene Fragen

1. Welche Zielkundensegmente werden für die erste reale Marktvalidierung priorisiert?
2. Welche Währungen, Regionen und steuerlichen Modelle werden zuerst unterstützt?
3. Welche Plattformfunktionen sind in jeder Lizenz enthalten und welche werden Add-ons?
4. Welche minimalen und maximalen Laufzeiten gelten je Service Offer?
5. Welche konkreten Gross-Margin-Ziele gelten je Servicefamilie?
6. Welche Service Credits sind rechtlich und kommerziell gewünscht?
7. Welche P1-Ereignisse rechtfertigen 24/7 Governance Acknowledgement?
8. Welche Reisezeit ist in welchen Paketen enthalten?

9. Welche öffentlichen Preise dürfen in einer realen Kundendemo dauerhaft angezeigt werden?
10. Wie werden Zertifizierungs- und Auditkosten externer Stellen integriert?
11. Welche Preisanpassungs- und Indexierungslogik ist für DACH und EU angemessen?
12. Welche Mindestdatenqualität ist Voraussetzung für Festpreise?
13. Welche Offers eignen sich für Self-Service, Partner Delivery oder White Label?
14. Welche Rabatte dürfen automatisiert vorgeschlagen, aber nicht freigegeben werden?
15. Welche Preis- und Vertragsdaten dürfen in Portfolio Analytics verwendet werden?

30. Ideen für später

- anonymisierte Preis- und Aufwandbenchmarks nach Branche und Komplexität,
- Outcome-basierter Bonus/Malus für klar kontrollierbare Services,
- Marketplace für geprüfte Partner- und Spezialistenleistungen,
- Budget-Navigator mit Mehrjahresrouten,
- CO2- und Reiseoptimierung neben Kosten und Kapazität,
- Vertragsklausel-Generator aus Service Charter und Price Book,
- automatische Erkennung von unter- oder überdimensionierten Paketen,
- FinOps-artige Servicekostenanalyse,
- Sandbox für Preisexperimente mit Fairness- und Margin-Prüfung,
- Mehranbieter-Vergleich und Kunden-Sourcing-Szenarien,
- Partner Revenue Share und White-Label-Modell,
- dynamische, aber governancekontrollierte Volumenbänder,
- Versicherung oder Warranty für eng definierte, kontrollierbare Outcomes,
- Self-Service-Katalog für kleine Unternehmen,
- öffentliche Trust- und Pricing-Seite mit konfigurierbaren Beispielkunden.

31. Abhängigkeiten zu Folgedokumenten

- **Dokument 15:** Kapazität, Skills, Kalender, Vor-Ort, Reise, Cost-to-Serve und Portfolio-Profitabilität.
- **Dokument 16:** Onboarding, Baseline, Strategie-DNA und kommerzielle Operational Readiness.
- **Dokument 17:** Connectoren, Workflow Designer und automatisierte Usage-Messung.
- **Dokument 18:** technische Pricing Rules, Entitlements, Billing Events, Mandantentrennung und Plattform-SLA.
- **Dokument 19:** Rechte, Audit Logs, Datenschutz, Vertragsdaten, Export und Abrechnungsintegrität.
- **Dokument 20A:** KI-Vorschläge für Katalog, Opportunity, Angebot und Pricing mit Guardrails.
- **Dokument 20B:** Agentenrollen für Service Design, Commercial Review, Pricing QA und Portfolio-Steuerung.
- **Dokument 20C:** Umsetzung von Catalog, Configurator, Price Book, Quote, Baseline, Tests und Demo-Daten.

32. Quellen- und Marktankerregister

S1 - isopilot Pricing. Öffentliche Preisbänder für ISO-27001-Software und Advisory. <https://www.isopilot.app/pricing> **S2 - Qontrol Pricing.** Öffentliche GRC-Plattformpreise. <https://www.qontrol.io/en/enduser/pricing> **S3 - vCISO Lite Pricing.** Öffentliche Software-/Servicepakete von USD 299 bis USD 1.499 pro Monat. <https://vcisolite.com/pricing> **S4 - vCISO.com Pricing.** Öffentliche Retainer- und Projektpreise. <https://www.vciso.com/pricing> **S5 - vCISO.com Cost Guide.** Veröffentlichte Marktspanne für vCISO-Retainer und Projekte. <https://www.vciso.com/vciso-cost> **S6 - Cybervize vCISO Kosten 2026.** DACH-orientierte Marktspanne und Preisfaktoren. <https://www.cybervize.de/de/blog/virtual-ciso-kosten-preismodelle> **S7 - Cybervize vCISO Service.** Öffentlicher Einstiegspreis für externen CISO. <https://www.cybervize.de/de/leistungen/vciso> **S8 - vCISO-EU.** Öffentliche europäische Paketpreise. <https://vciso-eu.com/> **S9 - AWS Marketplace Axipro vCISO Assurance Plan.** Beispiel eines laufenden Compliance- und Surveillance-Service mit individueller Preisbildung. <https://aws.amazon.com/marketplace/pp/prodview-ddpumpff5mo4e> **S10 - AWS Marketplace Rhymetec vCISO.** Beispiel eines mehrstufigen, individuell kalkulierten vCISO-Angebots. <https://aws.amazon.com/marketplace/pp/prodview-xzgm36fe2ilbw>

Hinweis: Alle Quellen wurden am 21.07.2026 geprüft. Preise können sich ändern und unterscheiden sich in Inhalt, Region, Steuer, Laufzeit und Leistungsumfang. Das Register begründet Designannahmen, ersetzt aber keine professionelle Preisstudie.

33. Änderungsprotokoll

Version	Datum	Änderung	Status
1.0	21.07.2026	Erstfassung mit Servicekatalog, Service-Tiefen, Paketarchitektur, SLA/OLA, Preisobjekten, Marktankern, illustrativen Preisbändern, Unit Economics, Change, Reise, Angebots-UX und Demo-Spezifikation	Erstellt